

NextGrid Technologies — M365 Security Checklist 2026

12 Steps to POPIA Compliance & Ransomware Protection — audit in 15 minutes | Updated: 25 July 2026 | For SA SMEs 5-50 staff

1. MFA enforced for all users

Microsoft Authenticator number matching only. No SMS. Block legacy auth. POPIA Sec 19 requires protected access.

2. Legacy authentication blocked

Old mail apps bypass MFA. Disable via Conditional Access policy.

3. Separate admin accounts

Never use daily email as Global Admin. Use admin@company.onmicrosoft.com with MFA.

4. Conditional Access: Block foreign logins

Block logins from outside SA if you don't operate there. Require compliant device.

5. Mailbox auditing enabled

Off by default. Required for POPIA breach investigation. Set via Purview.

6. Safe Links & Safe Attachments ON

Rewrites every link at click-time, detonates attachments in sandbox. Needs Business Premium or Defender P1.

7. Auto-forwarding to external blocked

Common attacker tactic — creates hidden forwarding rule. Block in Exchange > Mail flow.

8. DLP configured

Block ID numbers, bank details leaving org. Auto-encrypt client data.

9. OAuth app permissions reviewed

Revoke Mail.ReadWrite from dodgy apps. Check Azure AD > Enterprise Apps.

10. Unified audit log 1 year retention

Default 90 days, POPIA needs 1 year. Change in Purview > Audit.

11. Alerts: New Global Admin

SMS if someone makes themselves admin. Security & Compliance > Alert policies.

12. Immutable cloud backups

M365 recycle bin ≠ backup. Ransomware deletes it. Backup Exchange, OneDrive, SharePoint, Teams.